



Empresa Operativa Chile

Crear, operar y controlar una empresa chilena a través del tiempo

Contabilidad y tributación explicables · Reglas versionadas por año · Evidencia obligatoria
Sin servidor · Sin cuentas · Sin telemetría · Los datos no salen del dispositivo

Android · APK

Windows · MSI/EXE

Navegador · PWA

CLI · Node 20+

● EMPRESA REAL

Tu contabilidad, con bitácora de auditoría de cada cambio.

● SANDBOX

Empresa ficticia para practicar. Nunca toca la empresa real.

15 · Riesgos y deuda técnica

Documentación de sistema · Empresa Operativa Chile

Documento 15 de la serie

Versión del manifiesto 1.5.0 · commit 25f1a5e

Análisis del 2026-09-22

Documento técnico generado desde docs/system-documentation/. La fuente es el Markdown del repositorio: si este PDF y el Markdown difieren, manda el Markdown. Esta aplicación no presenta ni paga nada ante el SII y no es asesoría tributaria.

15 · Riesgos y deuda técnica

Este documento es informativo. No se corrigió nada. El encargo de esta serie es documentar, no arreglar: cada hallazgo lleva su evidencia, su ubicación y una recomendación, y la decisión de aplicarla es de quien mantiene el proyecto.

La conclusión, primero

Ninguno de los 22 hallazgos es un defecto de cálculo. El motor —que es la parte cara de equivocarse— está cubierto por 153 pruebas y sus reglas de negocio están fijadas por pruebas explícitas. Lo que aparece aquí es otra cosa: **puntos ciegos, silencios y afirmaciones que envejecieron.**

Los tres que conviene mirar primero:

1. **Una escritura puede perderse sin que nadie se entere** si `localStorage` se llena.
2. **La única superficie pública no tiene CSP**, porque GitHub Pages no admite cabeceras y el HTML no lleva la política dentro.

1. `docs/ARCHITECTURE.md` **afirma cifras que ya no son ciertas** — dice 10 vistas y 50 pruebas donde hoy hay 14 y 153.

Y la observación que más importa a largo plazo, que no es un hallazgo sino una condición: **el mecanismo de reglas por año nunca se ha ejercitado con dos años.** Todo el diseño apunta a que funcionará; nadie lo ha visto ocurrir.

Cómo leer la clasificación

Campo	Escala
Severidad	■ Crítica · ■ Alta · ■ Media · ■ Baja
Impacto	Qué pasa si se materializa
Probabilidad	Alta / Media / Baja, razonada a partir del código
Prioridad	P1 (antes del próximo release) · P2 (próximo ciclo) · P3 (cuando toque)

Severidad y prioridad no coinciden siempre: algo crítico y ya declarado en `SECURITY.md` es una decisión tomada, no una tarea pendiente.

Hallazgos confirmados

H-01 · Una escritura puede perderse en silencio si `localStorage` se llena

Ubicación	<code>packages/company-operations/store.mjs</code> · <code>createWebStore</code>
Evidencia	<code>write</code> y <code>append</code> llaman a <code>storage.setItem(...)</code> sin <code>try/catch</code> . La lectura sí tiene su <code>try/catch</code> ; la escritura no
Severidad	🔴 Alta · Impacto: la operación no se guarda y la excepción sube sin que nada la traduzca a un mensaje útil · Probabilidad: Baja hoy, creciente con el tiempo
Por qué crece	La bitácora es append-only y no tiene retención ni purga . <code>localStorage</code> ronda los 5–10 MB por origen. Una empresa con años de operaciones y bitácora acabará acercándose
Recomendación	Capturar <code>QuotaExceededError</code> en <code>write</code> / <code>append</code> , avisar en la interfaz e invitar a exportar. Añadir la prueba correspondiente
Prioridad	P1 — es el único hallazgo que puede costar datos del usuario

H-02 · La versión publicada en GitHub Pages no tiene CSP

Ubicación	<code>apps/web/src/index.html</code> , <code>.github/workflows/pages.yml</code>
Evidencia	La CSP la ponen <code>server.mjs</code> (cabecera) y <code>tauri.conf.json</code> . Se buscó <code>http-equiv</code> en todo <code>apps/web/src/</code> : ninguna coincidencia . GitHub Pages no admite cabeceras propias
Severidad	🔴 Alta · Impacto: la superficie más expuesta pierde la red de seguridad · Probabilidad: Baja de materializarse hoy
Matiz honesto	La app sigue sin hacer llamadas de red y el escapado por defecto sigue en pie. La CSP no es lo que impide la fuga; es lo que convertiría un futuro descuido en un error visible
Recomendación	Añadir la política como <code><meta http-equiv="Content-Security-Policy"></code> en <code>index.html</code> . Cubre las cuatro superficies de una vez
Prioridad	P1

H-03 · docs/ARCHITECTURE.md afirma cifras que ya no son ciertas

Ubicación	docs/ARCHITECTURE.md:39 y :47
Evidencia	Dice views/ 10 vistas y tests/ 50 pruebas . Reales, contadas: 14 vistas y 153 pruebas
Severidad	Media · Impacto: el documento de arquitectura es lo primero que lee alguien nuevo, y empieza desconfiando · Probabilidad: ya ocurrió
Contexto	El README.md raíz sí está al día (159 pruebas, 76 términos, 12 atajos, 14 etapas, 8 diapositivas). El drift está localizado en un archivo
Recomendación	Corregir las dos cifras. Mejor aún: generarlas, como ya se hace con el glosario, la guía y los atajos — el repositorio tiene el patrón resuelto y no lo aplicó aquí
Prioridad	P1 — cuesta dos líneas

H-04 · apps/android/ tiene dos lockfiles contradictorios

Ubicación	apps/android/pnpm-lock.yaml y apps/android/package-lock.json , ambos versionados
Evidencia	git ls-files los muestra a los dos. android.yml usa pnpm install --frozen-lockfile ; el package-lock.json no lo consume nadie
Severidad	Media · Impacto: alguien instala con npm, obtiene otro árbol y depura un problema que no existe · Probabilidad: Media
Contexto	Contradice una regla explícita del repositorio: packageManager: pnpm@11.2.2 , y los tres últimos commits del proyecto fueron precisamente sobre unificar en pnpm
Recomendación	Borrar apps/android/package-lock.json
Prioridad	P1 — es un git rm

H-05 · ☒ Resuelto en v1.5: el respaldo de disco copia todas las entidades

Ubicación	packages/company-operations/node-store.mjs · FILES y saveSnapshot
Evidencia	FILES incluye capital, cierres, perfil municipal y las cinco entidades de gobierno v1.5; saveSnapshot copia cada archivo además de snapshot.json
Severidad	Media · Impacto: el respaldo del almacén de disco queda incompleto como copia de archivos · Probabilidad: Baja — sólo afecta a la CLI
Atenuante importante	El snapshot.json interior sí lleva los datos, porque sale de exportAll() . No hay pérdida real; hay una asimetría que engaña al mirar el directorio
Recomendación	Mantener una prueba de cobertura para nuevas claves persistidas
Prioridad	Resuelto

H-06 · `append` en el almacén web reescribe la colección completa

Ubicación	<code>store.mjs</code> · <code>createWebStore.append</code>
Evidencia	Hace leer → empujar → <code>setItem</code> del arreglo entero. En <code>node-store</code> , el mismo método es un <code>fs.appendFileSync</code> de una línea
Severidad	 Media · Impacto: coste cuadrático al crecer la bitácora, y multiplica la exposición a H-01 · Probabilidad: Media a largo plazo
Matiz	Es una limitación de <code>localStorage</code> , no un descuido: no ofrece <code>append</code> . Lo que falta no es la técnica, es la mitigación (paginar la bitácora por año, o purgar con aviso)
Recomendación	Particionar la bitácora por año: <code>audit:2026</code> , <code>audit:2027</code>
Prioridad	P2

H-07 · Las 14 vistas no tienen ninguna prueba

Ubicación	<code>apps/web/src/views/*.js</code> — 14 archivos, más de 3.000 líneas
Evidencia	Ninguna de las 13 suites las ejecuta. <code>webapp.test.mjs</code> verifica presencia y contrato, no comportamiento
Severidad	 Media · Impacto: una regresión de interfaz sólo se detecta usando la app · Probabilidad: Alta
Atenuante	La lógica de negocio no está en las vistas , está en el motor, que sí está cubierto. Un fallo de vista se ve de inmediato
Agravante	<code>apps/web/src/views/capital.js</code> tiene 694 líneas , el segundo archivo más grande del repositorio
Recomendación	Empezar por lo barato y valioso: probar <code>lib/dom.js</code> (<code>esc</code> y <code>html</code>), que es un control de seguridad y son funciones puras
Prioridad	P2

H-08 · El escapado anti-XSS no tiene prueba propia

Ubicación	<code>apps/web/src/lib/dom.js</code> · <code>esc</code> y <code>html</code>
Evidencia	Ninguna suite las importa. Son el único control contra inyección de marcado
Severidad	 Media · Impacto: una regresión en el escapado pasaría desapercibida · Probabilidad: Baja
Recomendación	Media docena de aserciones. Es la prueba con mejor relación valor/coste de todo el repositorio
Prioridad	P1 — por lo barata, no por lo grave

H-09 · Dos de las tres validaciones del backend Rust no tienen prueba

Ubicación	<code>apps/contador-desktop/src-tauri/src/lib.rs</code>
Evidencia	Hay dos pruebas, ambas de <code>safe_mode</code> . Sin prueba: el saneo de <code>filename</code> en <code>export_file</code> y la validación del JSON en <code>save_workspace</code>
Severidad	 Media · Impacto: una regresión en el saneo del nombre permitiría escribir fuera de la carpeta prevista · Probabilidad: Baja
Recomendación	Dos pruebas al lado de las que ya existen
Prioridad	P2

H-10 · Resuelto en v1.5: manifests y lockfile sincronizados

Ubicación	<code>package.json</code> y <code>apps/contador-desktop/src-tauri/tauri.conf.json</code>
Evidencia	<code>tests/webapp.test.mjs</code> compara la versión 1.5.0 de raíz con Tauri, Cargo, la app, Android, su lockfile y el package del shell de escritorio
Severidad	 Media · Impacto: instaladores rotulados con una versión distinta de la que dice la documentación · Probabilidad: Media en el próximo bump
Recomendación	Conservar el gate al preparar cada release
Prioridad	Resuelto

H-11 · Cerrar un período son dos escrituras sin transacción

Ubicación	<code>workspace.mjs</code> · <code>closePeriod</code>
Evidencia	Escribe <code>period-closes</code> y después <code>closed-periods</code> . No hay transacción porque el almacén no la ofrece
Severidad	 Media · Impacto: una fotografía sin su índice — el mes parece abierto y hay un cierre registrado · Probabilidad: Muy baja
Recomendación	Escribir primero el índice, o detectar la incoherencia en <code>healthCheck</code>
Prioridad	P3

H-12 · Un JSON corrupto es indistinguible de un dato ausente

Ubicación	<code>store.mjs</code> · <code>readRaw</code> ; <code>node-store.mjs</code> · <code>read</code>
Evidencia	El <code>catch</code> devuelve el <code>fallback</code> sin distinguir «no existe» de «no parsea»
Severidad	 Media · Impacto: la app arranca vacía, y el usuario concluye que perdió sus datos cuando quizá siguen ahí, corruptos
Recomendación	Registrar la diferencia y exponerla en <code>healthCheck</code>
Prioridad	P3

H-13 · `audit.ndjson` marca las líneas corruptas y nadie las mira

Ubicación	<code>node-store.mjs</code> · <code>readAll</code> devuelve <code>{ corrupt: true, line }</code>
Evidencia	Ningún consumidor busca ese marcador
Severidad	 Baja
Recomendación	Contarlas en el diagnóstico
Prioridad	P3

H-14 · La bitácora crece sin techo

Ubicación	<code>workspace.mjs</code> · <code>audit()</code>
Evidencia	No hay retención, rotación ni purga. Y es deliberado: la ausencia de borrado es lo que la hace servir como evidencia
Severidad	 Media · Impacto: alimenta H-01 y H-06
Tensión de diseño	Purgar la bitácora contradice su propósito. Particionarla por año, no
Prioridad	P2, junto con H-06

H-15 · `workspace.mjs` concentra 1.388 líneas y toda la lógica de negocio

Evidencia	Es el archivo más grande del repositorio. Contiene ficha, capital, patrimonio, municipalidad, ejercicio anual, constitución, operaciones, obligaciones, períodos, respaldo y salud
Severidad	🟡 Media · Impacto: acoplamiento; cualquier cambio toca el mismo archivo
Atenuante fuerte	Está seccionado con comentarios , la cohesión es real (todo gira sobre el mismo espacio de trabajo) y la clase base ya se separó de la de Node. No es un archivo desordenado: es un archivo grande
Recomendación	Si crece más, extraer el ejercicio anual y la parte municipal a módulos propios. No refactorizar sin una razón concreta
Prioridad	P3

H-16 · `apps/web/src/views/capital.js` tiene 694 líneas

Segundo archivo más grande, y una vista. **Severidad** 🟡 Media, **Prioridad P3**. Es también el tema más difícil del producto —seis magnitudes distintas—, así que el tamaño tiene justificación.

H-17 · Los PDF de esta serie no se generan ni se verifican en CI

Ubicación	<code>scripts/build-system-docs.mjs</code> , <code>.github/workflows/ci.yml</code>
Evidencia	El glosario, la guía, los atajos y la presentación tienen su <code>--check</code> en CI. Esta serie no
Severidad	🟡 Media · Impacto: los PDF quedan desfasados del Markdown sin que nada avise · Probabilidad: Alta
Causa	Exigiría Chrome y <code>mmdc</code> en el runner, y hoy no están
Recomendación	O bien instalarlos en un trabajo aparte, o bien un <code>--check</code> ligero que compare fechas de modificación y falle si un <code>.md</code> es más nuevo que su <code>.pdf</code>
Prioridad	P2

H-18 · No hay vigilancia de dependencias de build

Evidencia	No se encontró configuración de Dependabot ni equivalente. Cero dependencias de producción —verificado en CI—, pero <code>apps/android</code> y <code>apps/contador-desktop</code> sí tienen las suyas
Severidad	🟢 Baja · Impacto: acotado al equipo que compila, no al usuario
Prioridad	P3

H-19 · No hay linter ni formateador

Evidencia	Sin ESLint, Prettier ni <code>tsconfig.json</code> . Hay JSDoc por todo el código y nadie lo comprueba
Severidad	 Baja · Impacto: hoy ninguno — el estilo es notablemente uniforme
Matiz	Esa uniformidad la sostiene una persona, no una herramienta. El día que entre alguien más, deja de estar garantizada
Prioridad	P3

H-20 · Dos pestañas abiertas: la última escritura gana

Evidencia	No hay bloqueo, ni evento <code>storage</code> , ni fusión
Severidad	 Baja · Probabilidad: Baja — es una app de un solo operador
Prioridad	P3

H-21 · `android.yml` y `desktop.yml` no corren en cada push

Evidencia	Sólo <code>workflow_dispatch</code> y <code>workflow_call</code> . Tardan 30 y 45 minutos
Severidad	 Media · Impacto: una regresión que sólo rompa el empaquetado aparece al publicar
Matiz	La decisión es razonable: 75 minutos por push es caro. Una ejecución nocturna sería un término medio
Prioridad	P3

H-22 · `docs/` tiene 74 archivos y ningún índice único

Evidencia	<code>docs/README.md</code> existe, pero conviven manual, guía, runbooks, políticas contables, árbol de decisión, presentación, glosario y ahora esta serie
Severidad	 Baja
Mitigación ya aplicada	El índice de esta serie declara qué documento es la fuente de verdad de cada tema, precisamente para no añadir confusión
Prioridad	P3

Riesgos que no son defectos

Cosas que están bien decididas y conviene entender antes de «arreglarlas».

#	Observación	Por qué no es un defecto
R-1	El mecanismo de reglas por año nunca se ha ejercitado con dos años	Está diseñado, probado y documentado. Pero <code>availableYears()</code> devuelve <code>[2026]</code> : el primer <code>rules/2027.json</code> es donde se sabrá si el esquema aguanta. REQUIERE VALIDACIÓN en su momento
R-2	Los datos no están cifrados	Declarado en <code>SECURITY.md</code> , con su contrapartida: tampoco salen del dispositivo
R-3	Los binarios no están firmados	Declarado en <code>SECURITY.md</code> y en cada release. Un certificado cuesta dinero y renovación
R-4	El APK es de depuración	Declarado. Publicar en Play exige firma de release
R-5	No hay autenticación local	Declarado. El control de acceso lo aporta el sistema operativo
R-6	El F29 no cubre todos los códigos	Limitación declarada del producto , no un fallo. <code>SECURITY.md</code> lo pone explícitamente fuera de alcance
R-7	El remanente de IVA no se reajusta (art. 27, D.L. 825)	Declarado en el código y en las advertencias de las reglas
R-8	La tasa de cada comuna no está en el repositorio	Correcto : el archivo guarda el rango legal. Publicar tasas que nadie verificó sería el error
R-9	<code>HOST</code> puede exponer el servidor a la red	El valor por defecto es seguro y la razón está comentada. El riesgo lo introduce quien lo cambia
R-10	Todo es síncrono y de un solo hilo	Decisión de arquitectura consciente. Cambiarla obligaría a rehacer las catorce vistas

Decisiones que requieren validación humana

Ninguna de éstas la puede resolver una revisión de código.

#	Decisión	Quién la toma
V-1	¿Siguen vigentes las tasas de 2026? El propio archivo advierte que BCN/LeyChile no respondió el 16-08-2026	Quien mantiene las reglas, contra las fuentes oficiales
V-2	¿Se firma el código y el APK?	Depende de presupuesto
V-3	¿Se cifran los datos en reposo? Cambia el modelo de recuperación: sin contraseña no hay respaldo legible	Producto
V-4	¿Se purga o se particiona la bitácora? Tiene implicaciones sobre su valor como evidencia	Producto
V-5	¿Entra el empaquetado en CI nocturno?	Coste frente a detección temprana
V-6	¿Se generan las cifras de <code>ARCHITECTURE.md</code> o se corrigen a mano?	Mantenimiento

Resumen por prioridad

Prioridad	Hallazgos	Esfuerzo estimado
P1	H-01, H-02, H-03, H-04, H-08	Bajo. Cuatro son de minutos; sólo H-01 exige pensar la interfaz del aviso
P2	H-05, H-06, H-07, H-09, H-10, H-14, H-17	Medio
P3	H-11, H-12, H-13, H-15, H-16, H-18, H-19, H-20, H-21, H-22	Variable

INFERENCIA : las cinco P1 son, en conjunto, menos de una jornada de trabajo, y cierran el único riesgo de pérdida de datos y el único hueco de seguridad no declarado.

Lo que esta revisión NO buscó

Para que la ausencia de hallazgos no se lea como una garantía que nadie dio:

- No se hicieron pruebas de penetración ni escaneos activos.
- No se auditó la corrección **tributaria** de las fórmulas contra la normativa. Se verificó que cada

tasa lleva su fuente y que el sistema falla en vez de degradar; **no que el resultado sea el que el SII aceptaría.**

- No se midió cobertura real de pruebas: el mapa de 12 es cualitativo.
- No se ejecutaron el APK, los instaladores ni las pruebas de Rust.
- No se revisaron los 74 documentos previos de docs/ en busca de más drift; sólo se comprobaron las

cifras de estado en los principales.
